Práctica guiada: Shodan

Buscador de dispositivos conectados

Módulo	Seguridad y Alta Disponibilidad
Alumno	Pedro Hosannah
Curso	2º ASIR
Fecha	09/09/2026

En esta práctica he utilizado Shodan para realizar reconocimiento pasivo de activos expuestos en Internet. El objetivo ha sido aprender a filtrar resultados, identificar dispositivos y servicios, y explicar los riesgos que puede tener dejar información técnica accesible públicamente.

Durante la práctica no he intentado acceder a cuentas, modificar dispositivos ni probar contraseñas. Me he limitado a observar la información que Shodan muestra públicamente y a documentarla mediante capturas de pantalla.

1. Introducción

Shodan es un buscador que no se centra en páginas web como haría un buscador tradicional, sino en servicios y dispositivos conectados a Internet. Al realizar una búsqueda, puede mostrar información como direcciones IP, puertos abiertos, cabeceras HTTP, certificados, banners de servicios, productos detectados y datos aproximados de ubicación.

Esta herramienta es útil en Seguridad y Alta Disponibilidad porque ayuda a comprender qué información puede quedar expuesta hacia el exterior. En una organización real, esta revisión serviría para detectar servicios innecesarios, configuraciones poco seguras o tecnologías que convendría actualizar.

2. Objetivo de la práctica

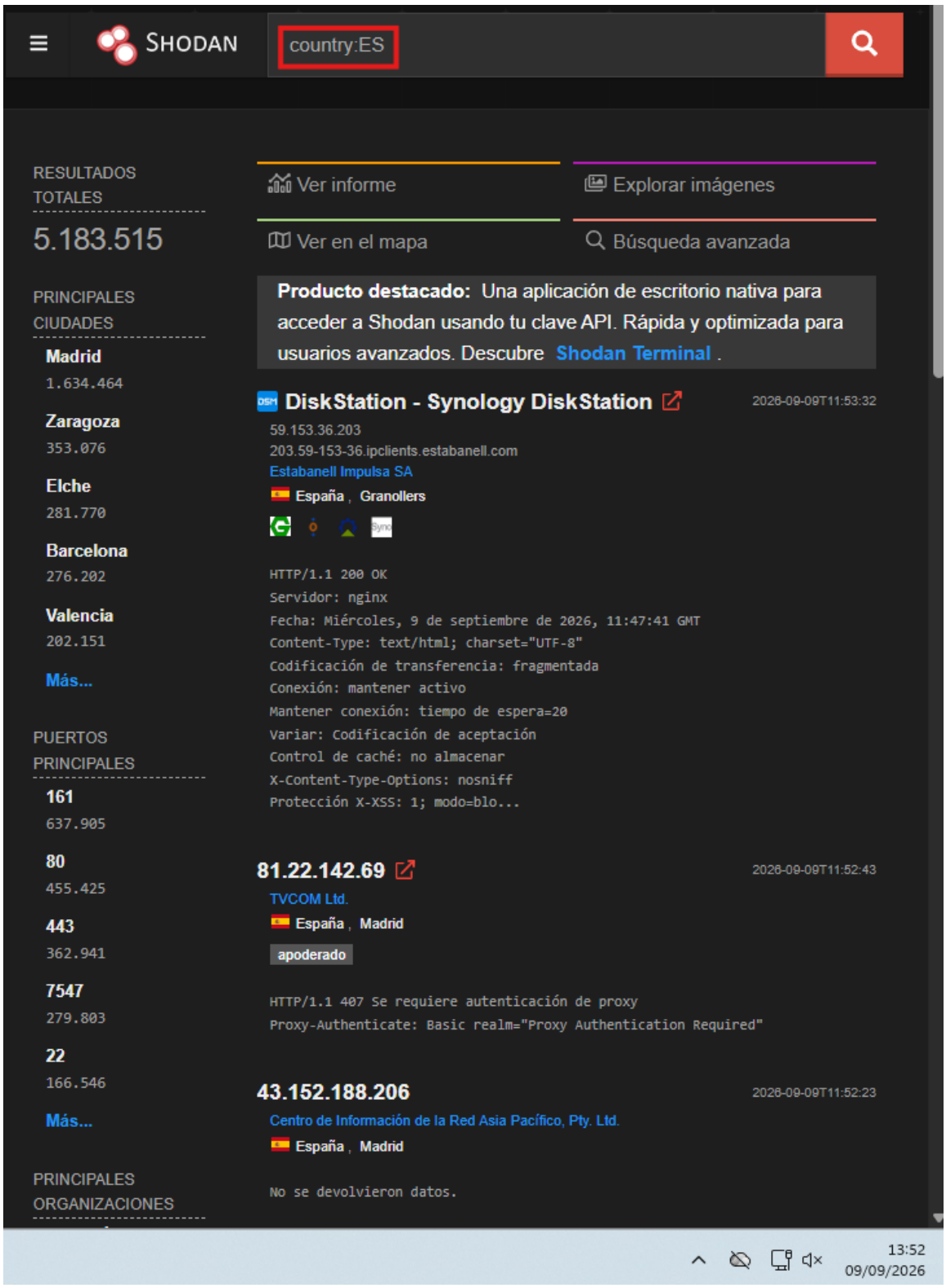
El objetivo de esta práctica ha sido aprender a utilizar Shodan de forma guiada, aplicando filtros de búsqueda y analizando tres tipos de activos expuestos: cámaras web públicas, servidores web y dispositivos de red MikroTik. En cada caso he observado qué información aparece publicada, qué riesgos puede suponer y qué medidas básicas se podrían aplicar para reducir la exposición.

3. Fase 1: primeros pasos y filtros en Shodan

Para empezar he realizado varias búsquedas sencillas y combinadas. La finalidad de esta fase era comprobar cómo cambian los resultados al filtrar por país, ciudad, puerto, organización o sistema operativo. Estos filtros permiten reducir búsquedas demasiado amplias y centrarse en activos concretos.

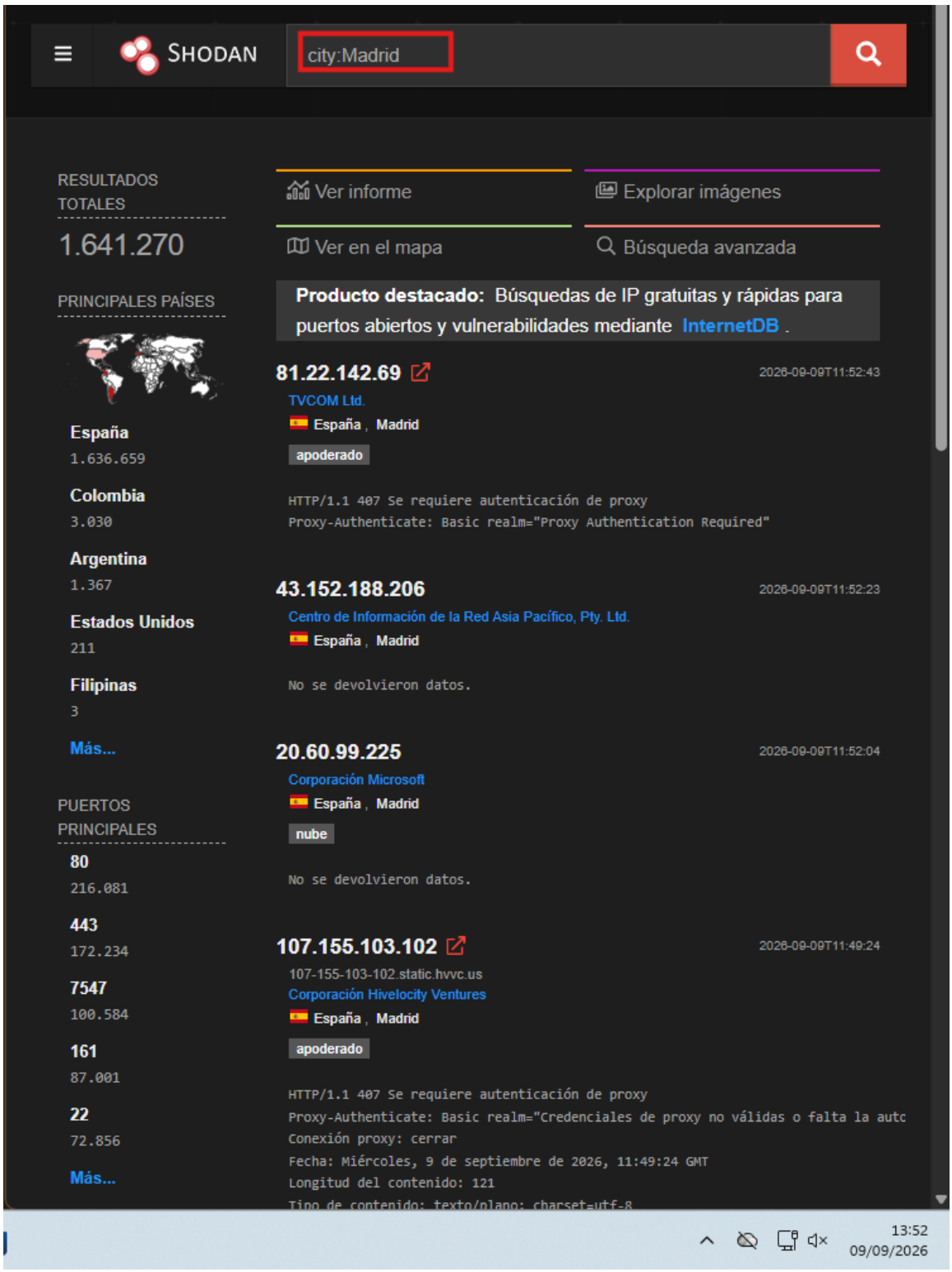
3.1 Filtro por país

Primero he usado el filtro country:ES para limitar los resultados a dispositivos localizados en España. Esta búsqueda devuelve una cantidad muy alta de activos, por lo que sirve como punto de partida general, pero no es suficiente para analizar un caso concreto.



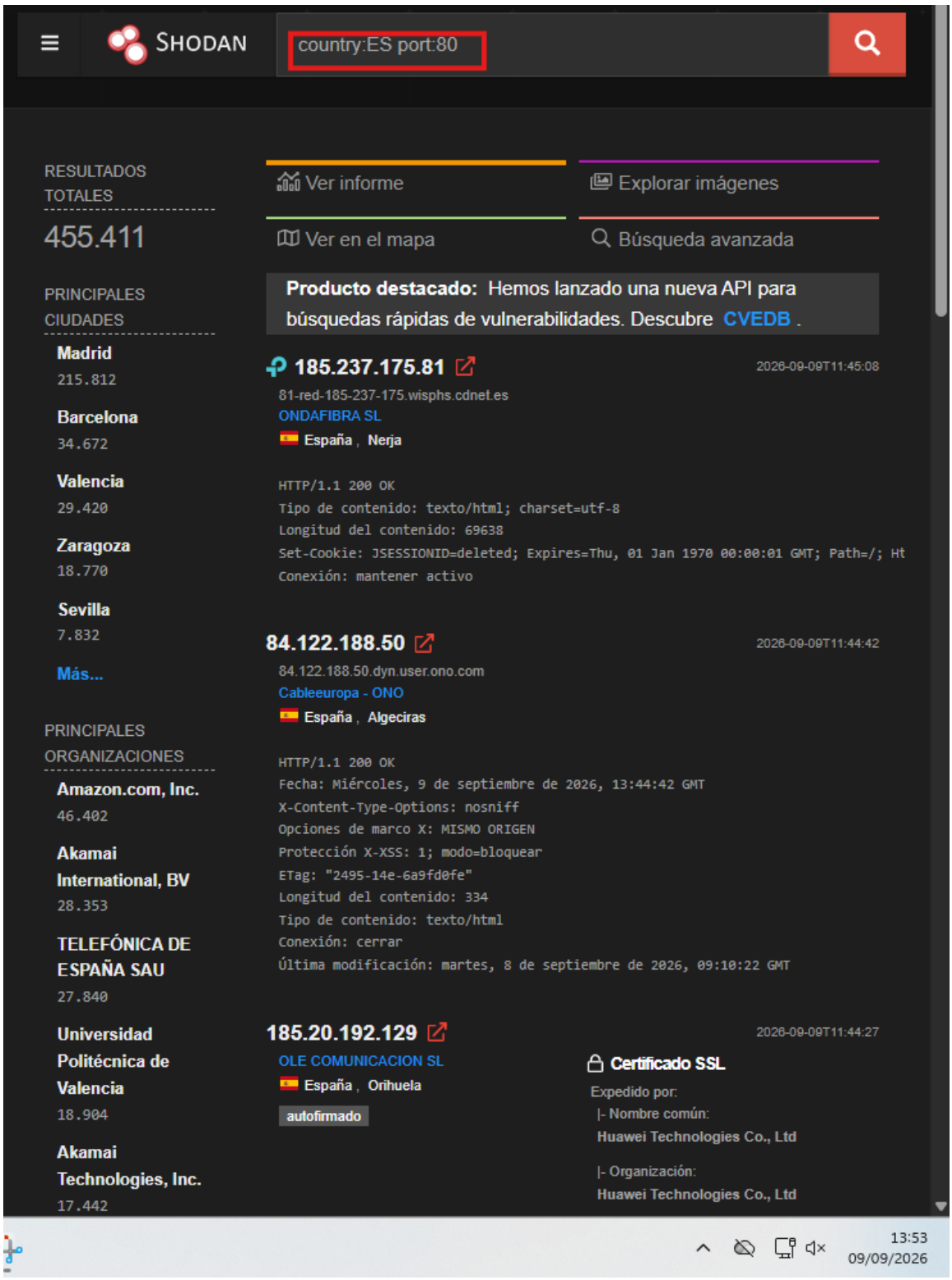
3.2 Filtro por ciudad

Después he utilizado city:Madrid para comprobar cómo se puede acotar la búsqueda a una ciudad concreta. En este caso los resultados se reducen a dispositivos asociados a Madrid, lo que hace más manejable la información obtenida.



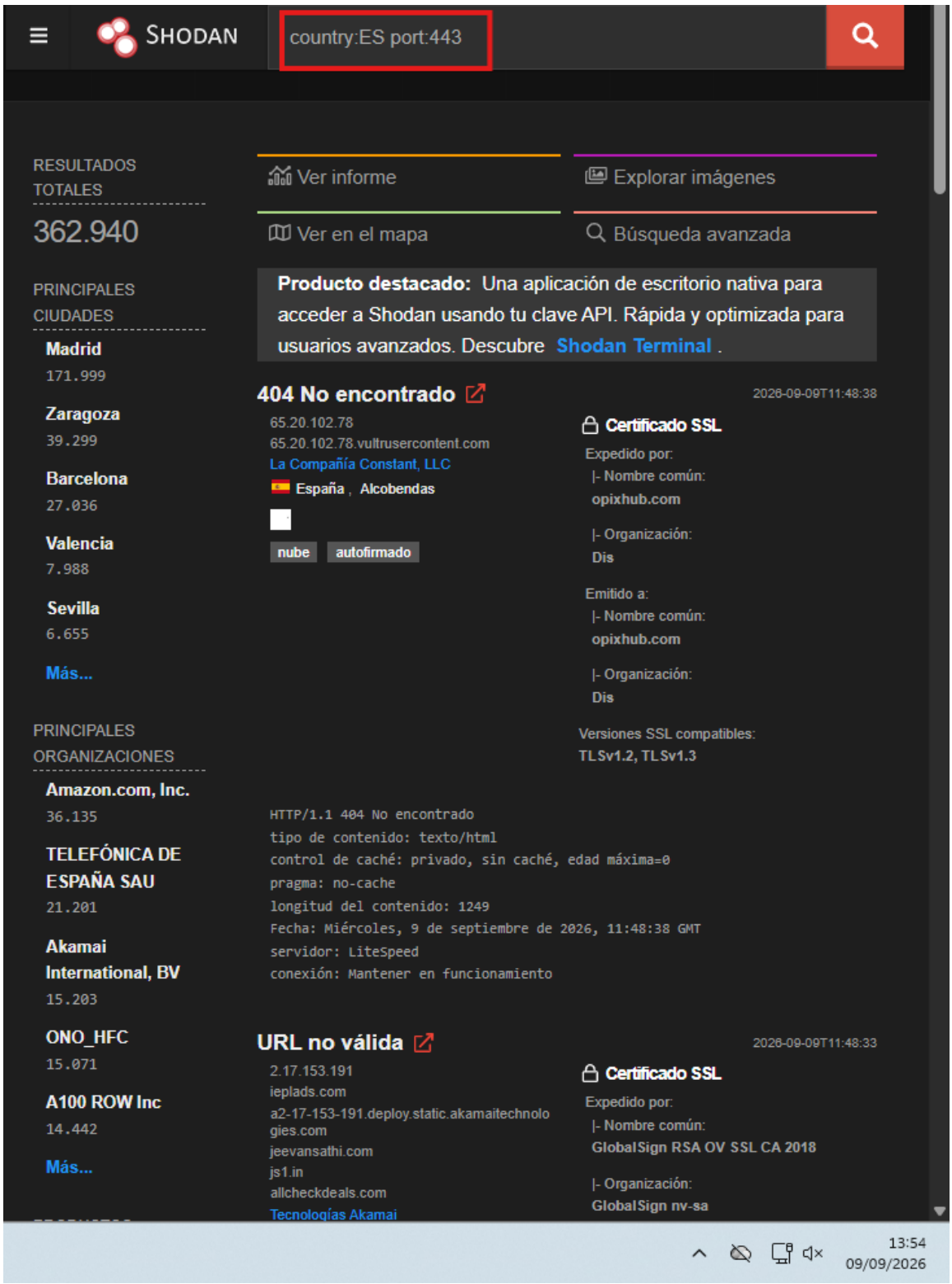
3.3 Filtro por puerto HTTP

A continuación he combinado el país con el puerto 80 mediante country:ES port:80. El puerto 80 se utiliza normalmente para servicios web HTTP. Esta búsqueda permite localizar servidores o dispositivos que publican algún servicio web sin cifrado HTTPS.



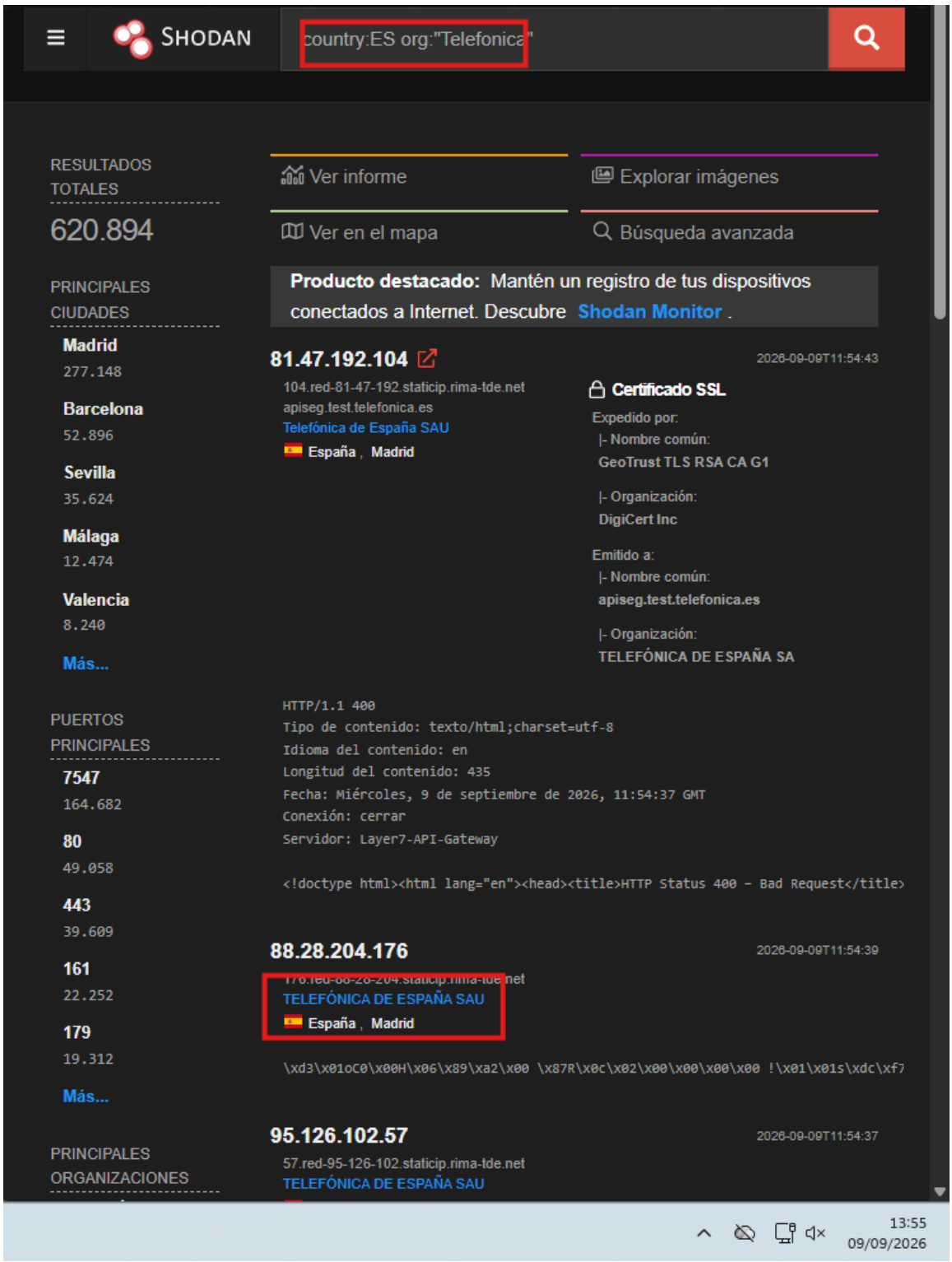
3.4 Filtro por puerto HTTPS

También he buscado activos con el puerto 443 abierto usando country:ES port:443. Este puerto suele estar asociado a HTTPS. En los resultados se puede observar información relacionada con certificados SSL y respuestas de servicios web.



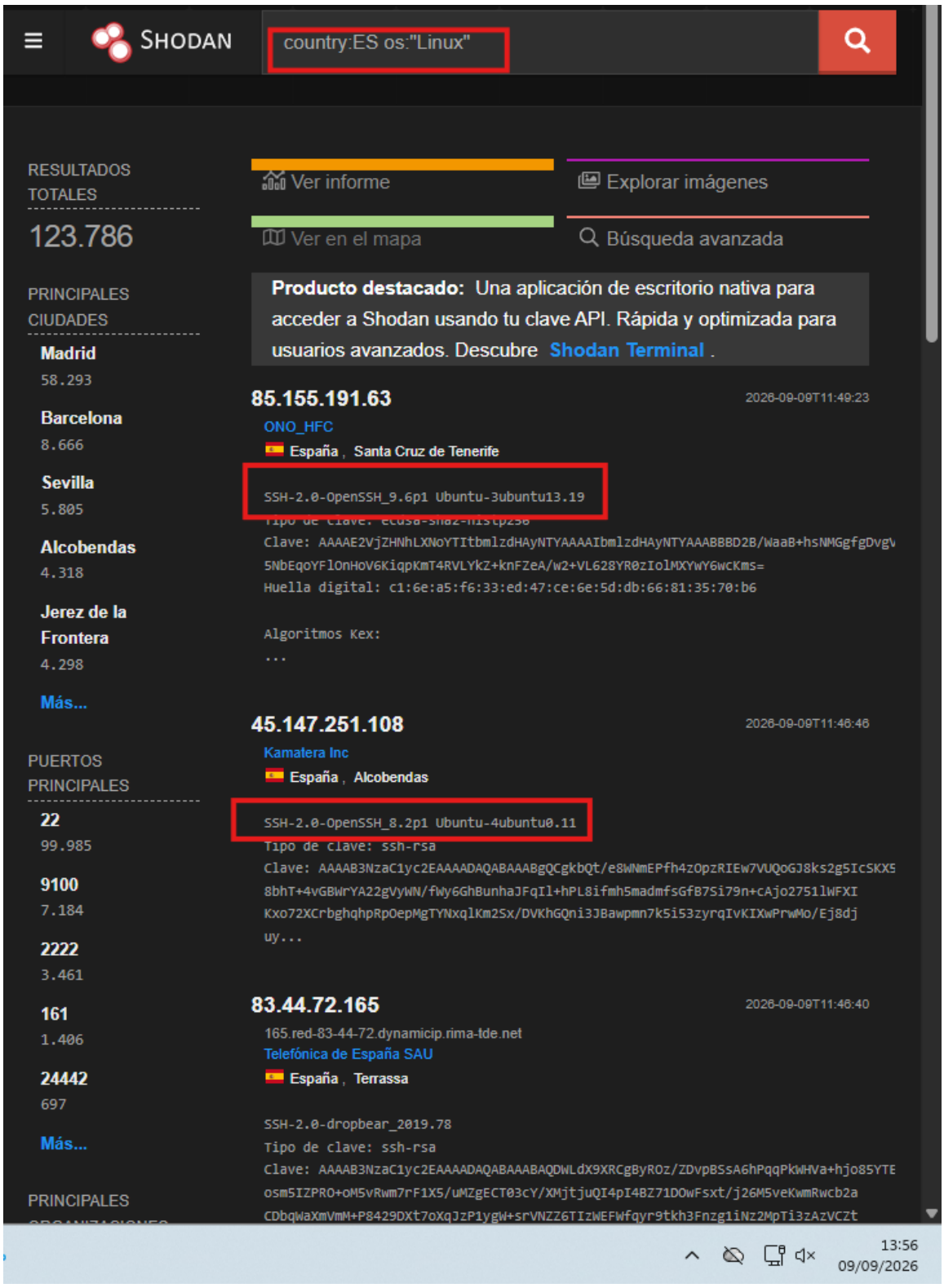
3.5 Filtro por organización

Para practicar el filtro por organización he usado country:ES org:"Telefonica". Con esta consulta Shodan muestra resultados asociados a esa organización o proveedor. Este tipo de filtro puede ser útil en auditorías autorizadas, cuando se quiere revisar qué activos aparecen asociados a una empresa concreta.



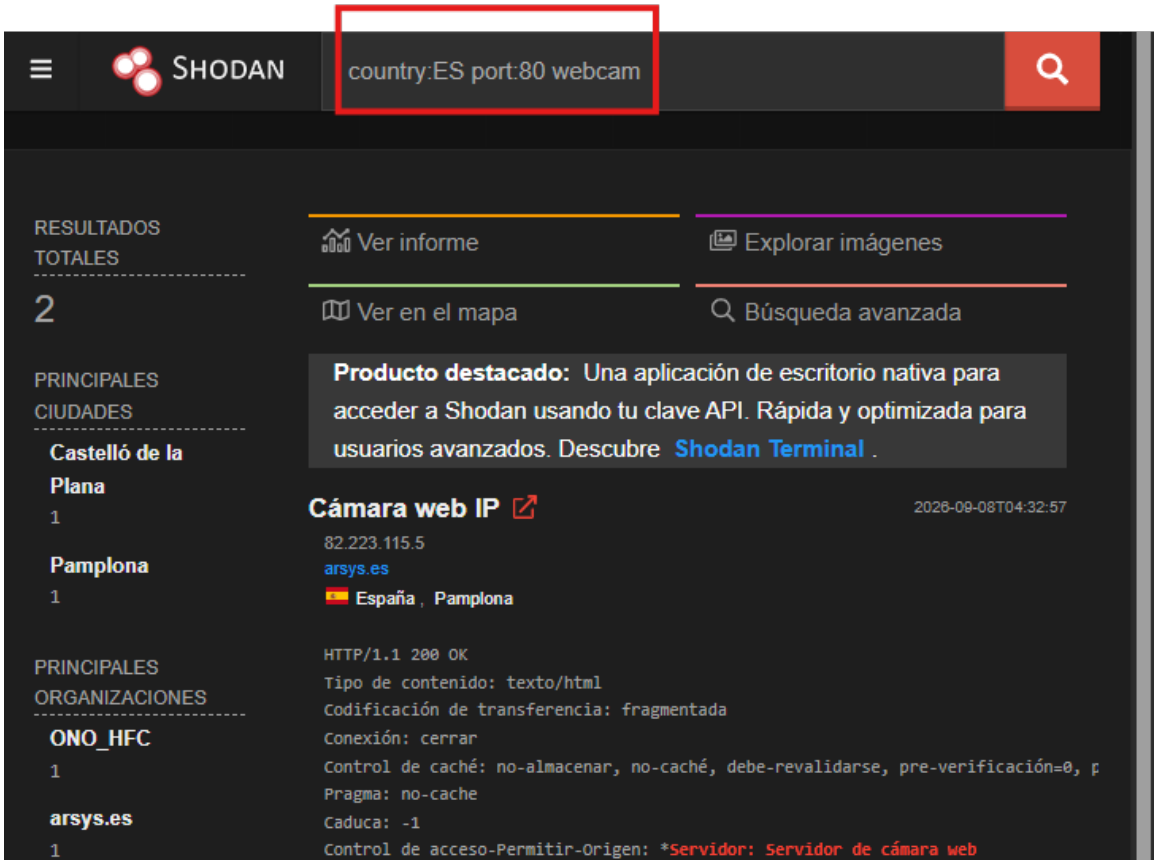
3.6 Filtro por sistema operativo

Por último he usado country:ES os:"Linux" para localizar dispositivos en España en los que Shodan identifica Linux como sistema operativo. En varios resultados aparecen banners de SSH con OpenSSH y Ubuntu, lo que demuestra que un servicio puede revelar datos técnicos del sistema.

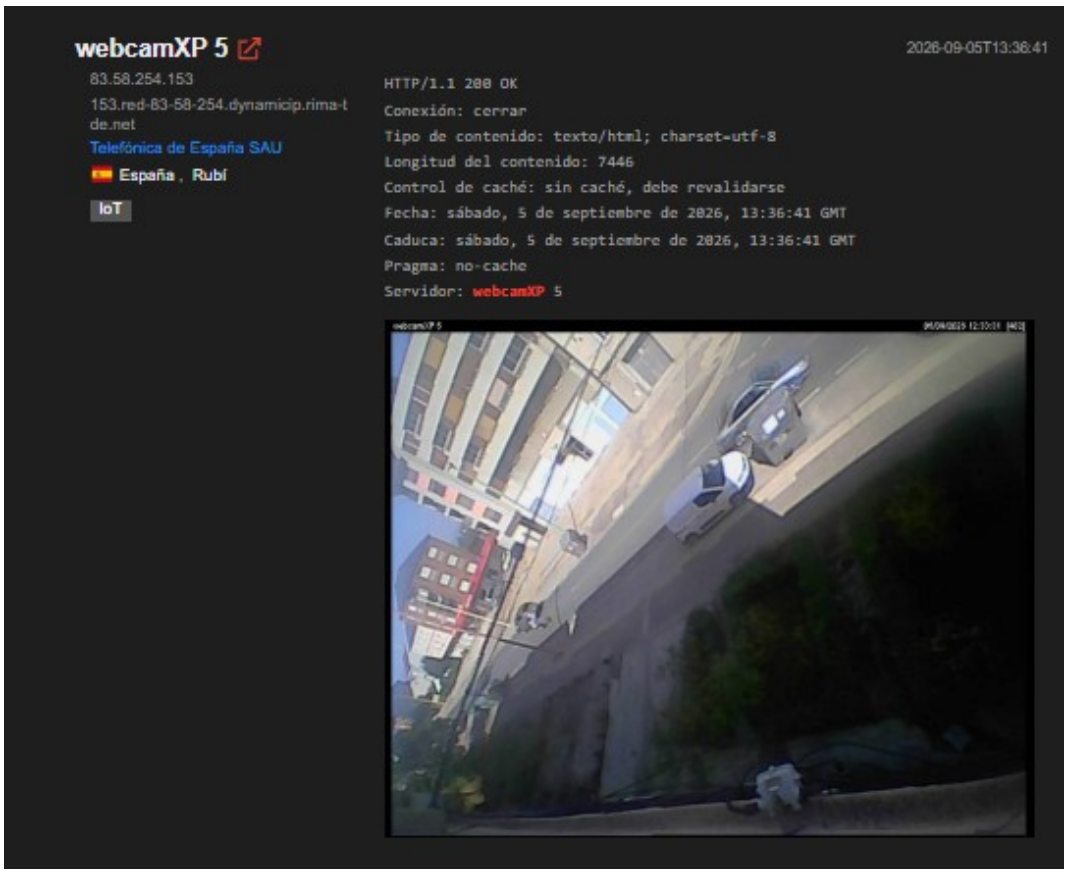


4. Reto 1: búsqueda de cámaras web abiertas

En el primer reto he buscado cámaras accesibles públicamente. Para ello he utilizado el filtro country:ES port:80 webcam. Durante la revisión descarté cualquier resultado que mostrase interiores de viviendas o espacios privados, porque la práctica indica que debe preservarse la intimidad de las personas y que no se deben recoger imágenes del interior de domicilios.



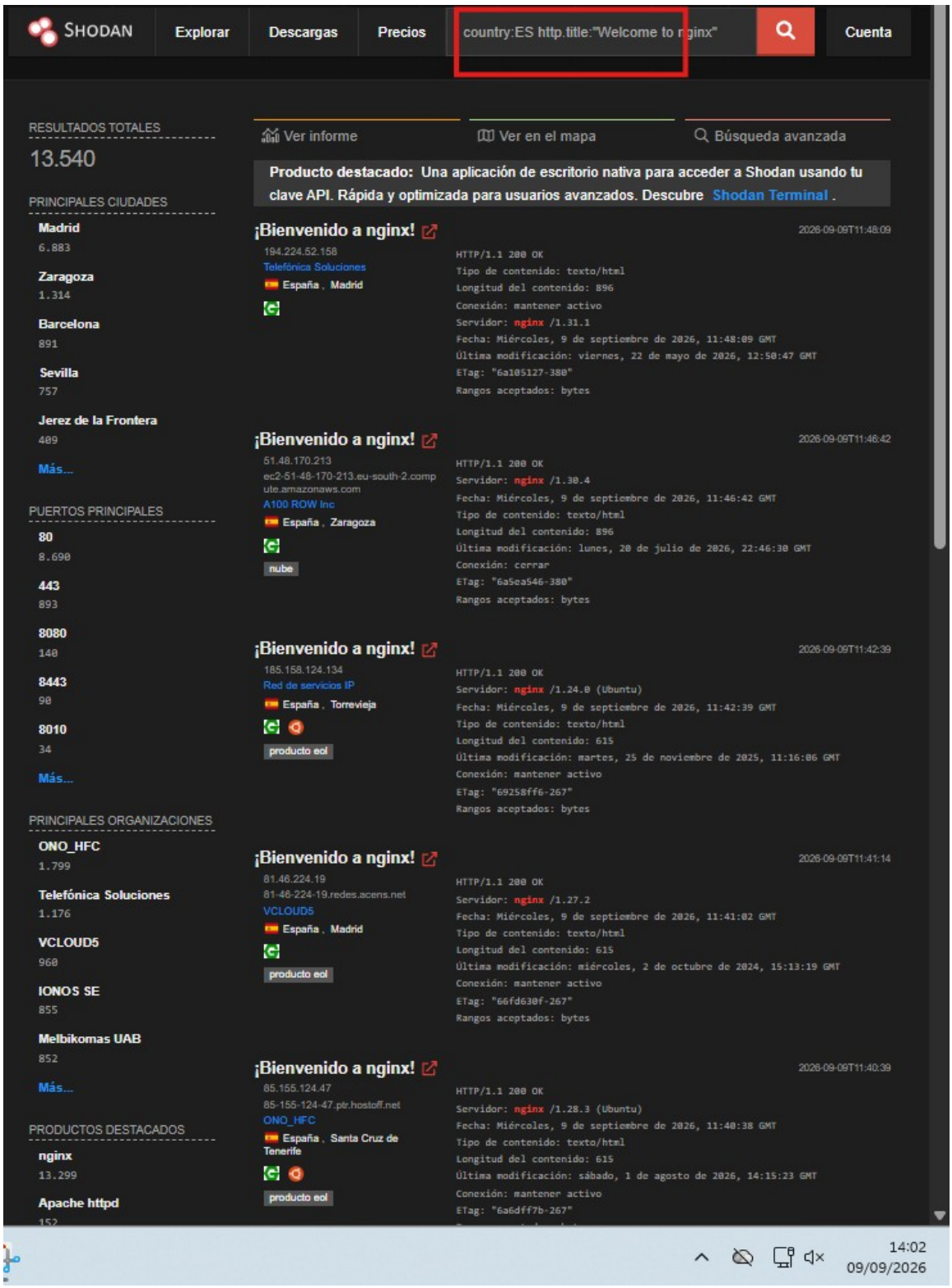
Finalmente seleccioné una cámara que muestra una zona exterior de una calle. En la ficha de Shodan se identifica el servicio webcamXP 5, una respuesta HTTP correcta y una ubicación aproximada en Rubí, España. El objetivo no fue acceder ni controlar la cámara, sino comprobar qué información visual y técnica aparece expuesta públicamente.



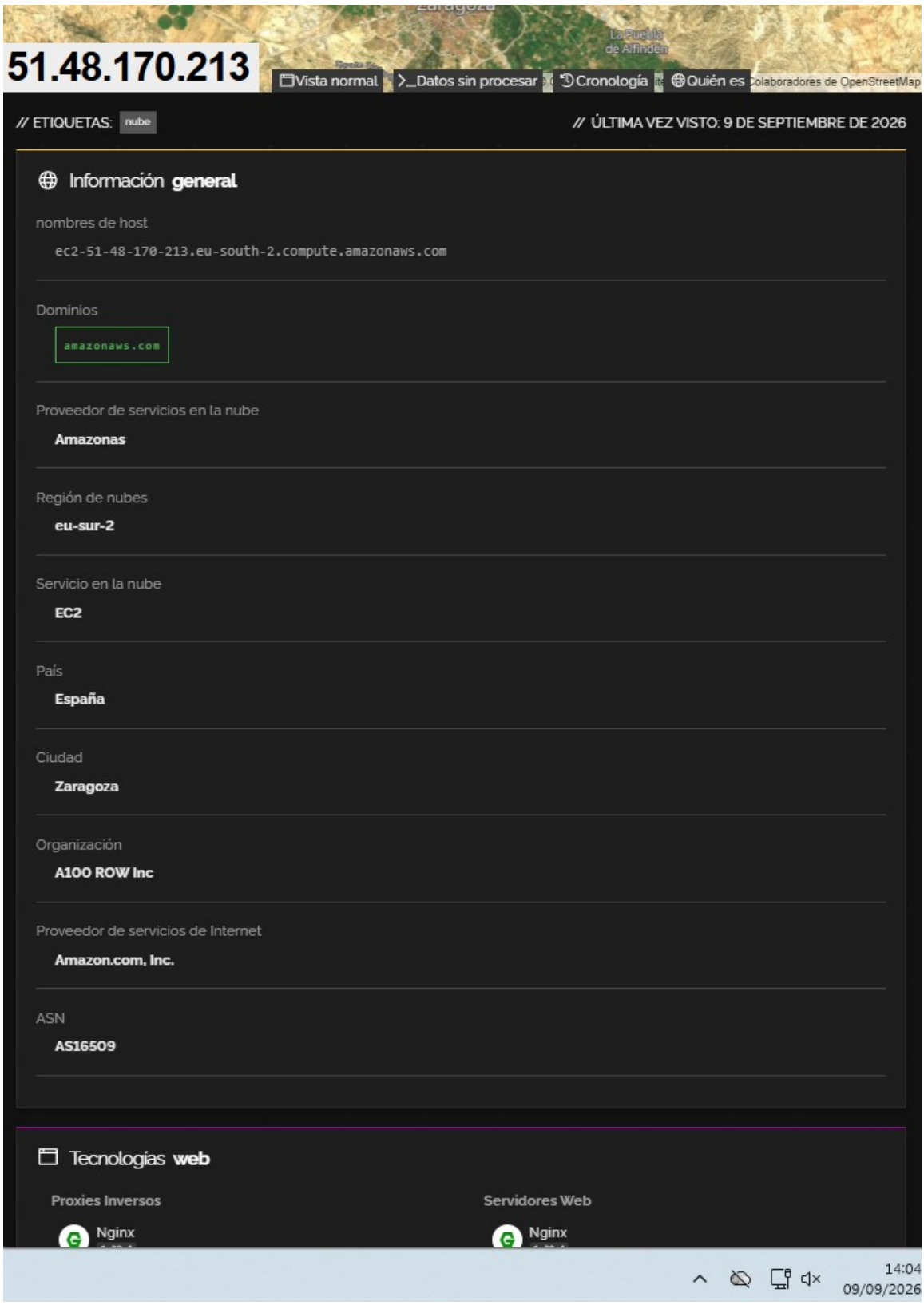
En este caso la información expuesta permite ver parte de una vía pública y conocer detalles técnicos como el servidor utilizado. Aunque la imagen no corresponde a un domicilio, sigue siendo una exposición que conviene controlar. Si una cámara estuviera mal configurada o mostrase zonas privadas, podría afectar a la privacidad de personas o instalaciones. Como medida de protección, lo adecuado sería evitar publicar cámaras directamente en Internet, usar autenticación, actualizar el software y limitar el acceso a usuarios o redes autorizadas.

5. Reto 2: auditoría de servidores web expuestos

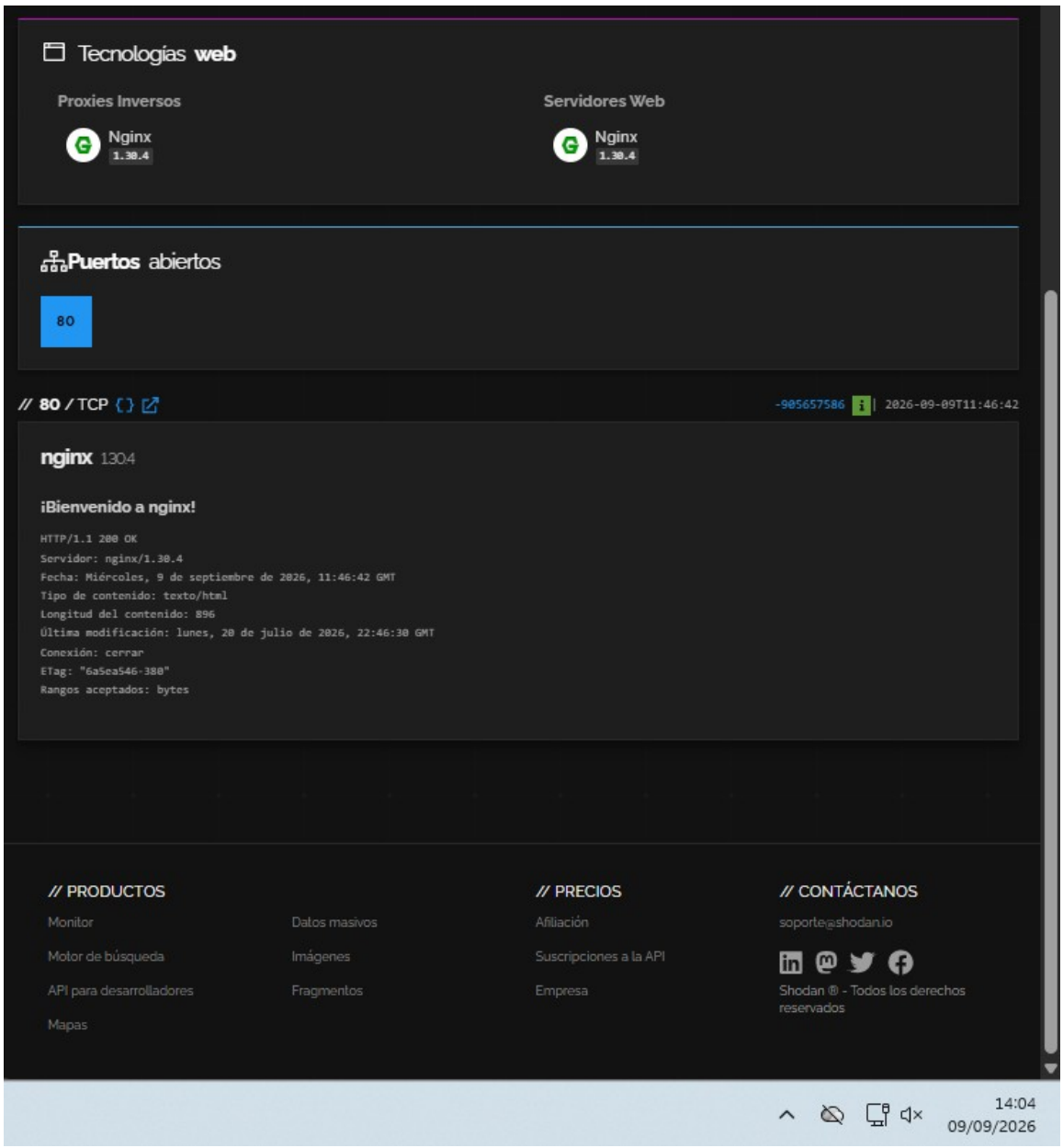
En el segundo reto he buscado servidores web en España usando una consulta relacionada con la página de bienvenida de Nginx. El filtro utilizado ha sido country:ES http.title:"Welcome to nginx". Esta búsqueda permite localizar servidores que muestran una página por defecto o una instalación visible de Nginx.



Entre los resultados he seleccionado el activo 51.48.170.213, asociado a una instancia EC2 de Amazon en la región eu-south-2. En la información general aparecen datos como el proveedor cloud, el país, la ciudad, la organización y el proveedor de servicios de Internet. Esta información permite clasificar el activo como un servidor web alojado en la nube.



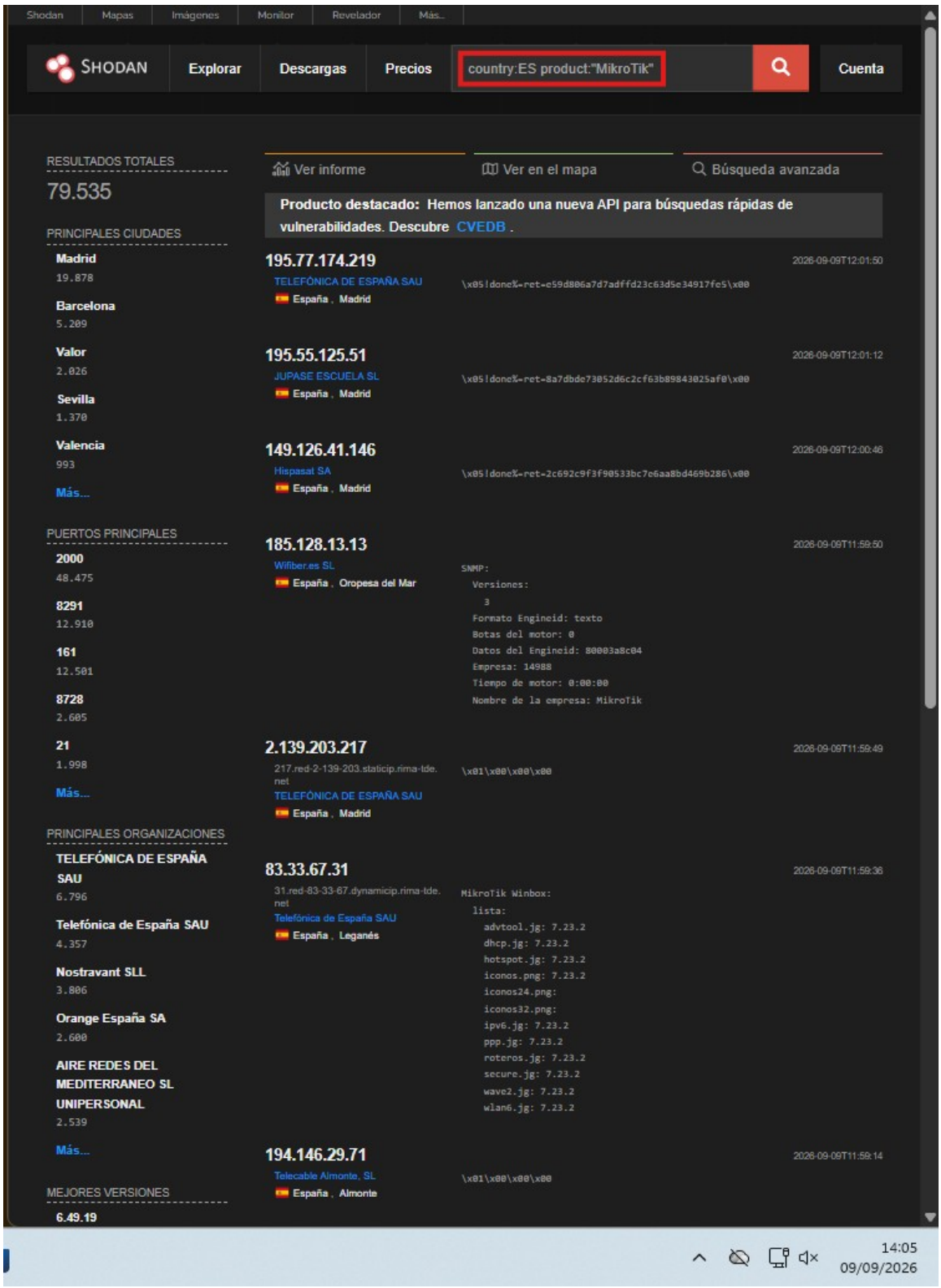
Al revisar el apartado del puerto 80/TCP, Shodan muestra que el servidor responde con HTTP/1.1 200 OK y que el servicio identificado es nginx/1.30.4. Esta parte es importante porque permite obtener la IP, el puerto y la versión exacta del servidor web reportada por el banner.



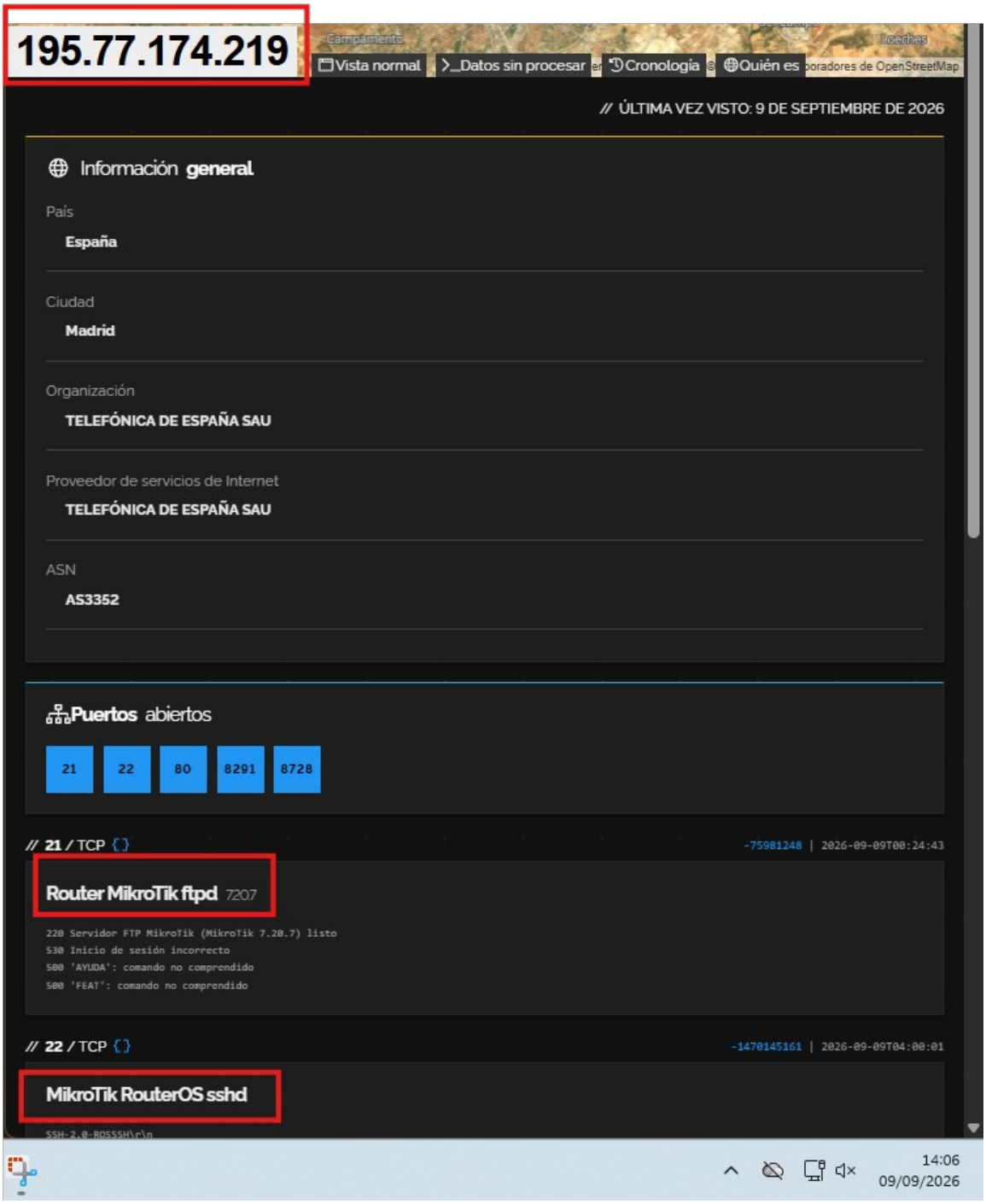
El hecho de que un servidor muestre su versión exacta no significa por sí solo que sea vulnerable, pero sí facilita el reconocimiento. Un atacante podría usar esa información para buscar fallos conocidos de esa versión o para preparar ataques más dirigidos. Como medidas básicas, se debería mantener el servidor actualizado, revisar la configuración, eliminar páginas por defecto que no sean necesarias y reducir la información técnica visible en las respuestas.

6. Reto 3: análisis de servicios industriales o routers

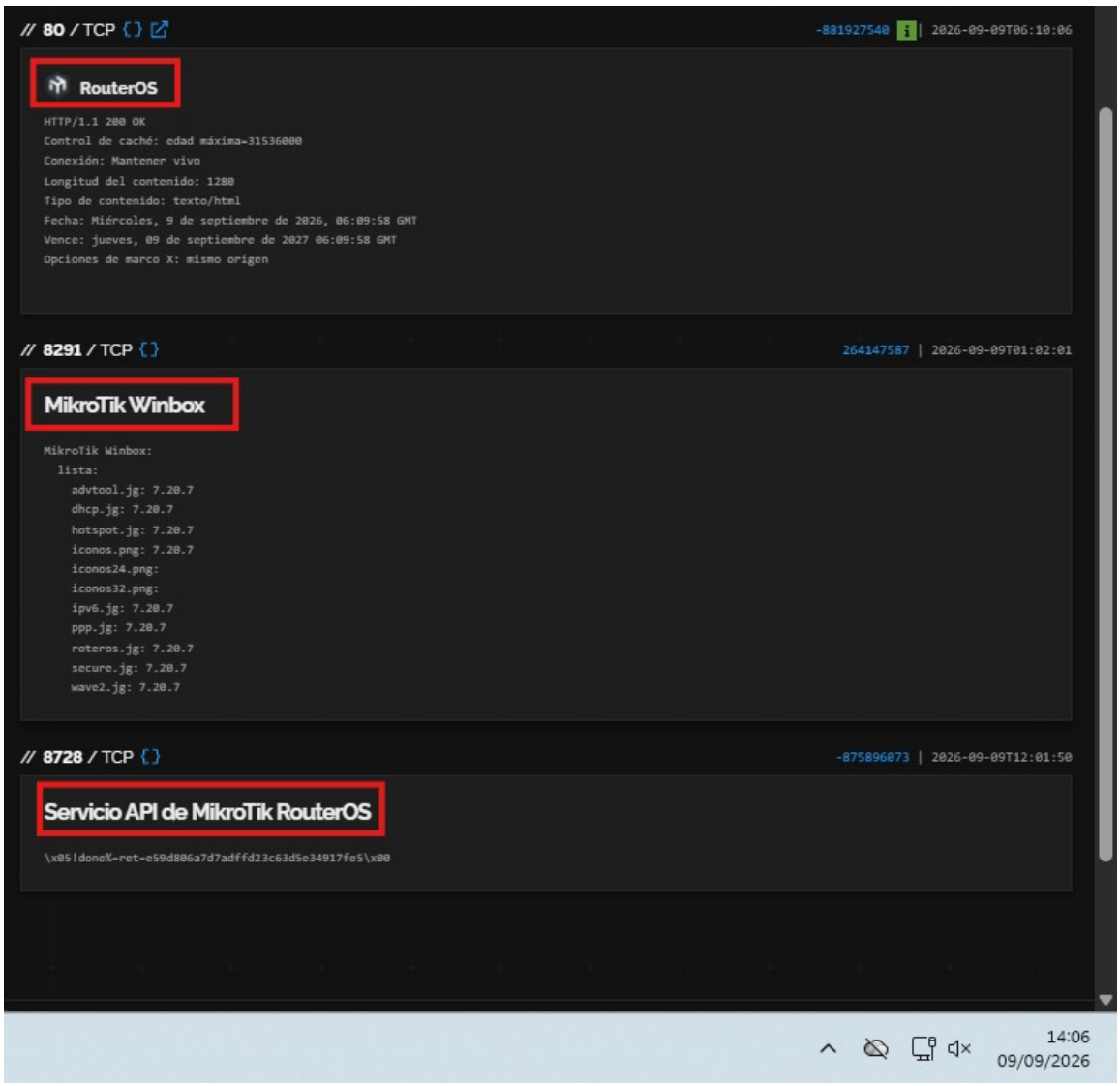
En el tercer reto he investigado dispositivos MikroTik usando el filtro country:ES product:"MikroTik". Este tipo de búsqueda permite localizar routers o servicios relacionados con RouterOS que aparecen expuestos en Internet. El objetivo ha sido analizar el riesgo de tener servicios de administración accesibles públicamente.



Para el análisis he seleccionado el dispositivo 195.77.174.219, ubicado en Madrid y asociado a Telefónica de España SAU. En su ficha se observan varios puertos abiertos, entre ellos 21, 22, 80, 8291 y 8728. Esto indica que el dispositivo ofrece varios servicios accesibles desde Internet.



En la parte inferior de la ficha se observan servicios concretos como Router MikroTik FTP en el puerto 21, MikroTik RouterOS SSH en el puerto 22, RouterOS por HTTP en el puerto 80, MikroTik Winbox en el puerto 8291 y el servicio API de MikroTik RouterOS en el puerto 8728. En algunos apartados también aparece la versión 7.20.7, lo que proporciona información técnica adicional sobre el dispositivo.



El principal riesgo en este caso es que hay varios servicios de administración o gestión del router visibles desde Internet. Aunque no se puede afirmar que el equipo sea vulnerable solo por aparecer en Shodan, sí existe una superficie de exposición mayor. Servicios como SSH, Winbox o la API deberían estar protegidos y no quedar abiertos a cualquier origen. Para reducir el riesgo, sería recomendable desactivar servicios innecesarios, restringir el acceso mediante firewall, usar VPN para la administración, aplicar contraseñas robustas y mantener RouterOS actualizado.

7. Impacto de la exposición

La exposición de activos en Internet puede tener consecuencias técnicas y organizativas. A nivel técnico, publicar servicios innecesarios aumenta las posibilidades de que alguien recopile información sobre la red, los puertos, los productos utilizados y las versiones instaladas. Esa información puede emplearse en una fase de reconocimiento previa a un ataque.

A nivel organizativo, una exposición mal controlada puede afectar a la privacidad, a la reputación y a la disponibilidad de los servicios. Por ejemplo, una cámara mal configurada puede mostrar información sensible, un servidor con información de versión puede facilitar ataques dirigidos y un router con paneles de administración abiertos puede convertirse en un punto crítico si no está bien protegido.

8. Medidas de mitigación

Después de analizar los tres casos, las medidas más importantes serían revisar qué servicios están realmente publicados, cerrar los puertos que no sean necesarios, limitar la administración remota a redes autorizadas, utilizar VPN para el acceso de gestión, mantener los sistemas actualizados y evitar mostrar información técnica innecesaria en banners o páginas por defecto.

También sería conveniente realizar revisiones periódicas desde el punto de vista externo, de forma autorizada, para comprobar qué información aparece realmente en Internet sobre una organización. Así se podrían corregir exposiciones antes de que supongan un problema de seguridad.

9. Conclusión

Con esta práctica he aprendido a utilizar Shodan para localizar activos expuestos y a interpretar parte de la información que ofrece la herramienta. He practicado filtros por país, ciudad, puerto, organización y sistema operativo, y después he aplicado esos conocimientos a cámaras, servidores web y routers MikroTik.

La conclusión principal es que la exposición de un dispositivo en Internet no siempre significa que exista una vulnerabilidad, pero sí puede revelar información útil para un atacante. Por eso es importante controlar qué servicios se publican, proteger correctamente los accesos y mantener los sistemas actualizados. Esta práctica me ha ayudado a entender mejor la diferencia entre un activo expuesto y un activo vulnerable, y la importancia de reducir la superficie de ataque.